

INFORME FINAL — ERSO 2026-003

- [INFORME FINAL — ERSO 2026-003](#)
 - [Creación del DID y DID Document del titular](#)
 - [Cómo leer este informe](#)
 - [Contenido](#)
 - [Resumen ejecutivo](#)
- [PARTE I — MARCO CONCEPTUAL: los términos que necesitas](#)
 - [1. La historia en cinco minutos](#)
 - [2. Diccionario de términos](#)
 - [3. Las siete ideas madre](#)
 - [4. El método de trabajo: cómo se piensa un criterio](#)
- [PARTE II — QUÉ PIDE LA ERSO 003, EXPLICADO FRASE POR FRASE](#)
 - [5. La ficha del documento](#)
 - [6. Capacidades del proceso](#)
 - [7. Condiciones del proceso](#)
 - [8. Descripción del proceso](#)
 - [9. Qué debe hacer: los seis pasos](#)
 - [10. Los cuatro criterios de aceptación](#)
- [PARTE III — EL PROYECTO: QUÉ SE CONSTRUYÓ PARA ESTA ERSO Y CÓMO ESTÁ MONTADO](#)
 - [11. Visión general](#)
 - [12. El entorno para esta ERSO](#)
 - [13. Mapa de requisitos a implementación](#)
- [PARTE IV — LABORATORIOS DE DEMOSTRACIÓN: LA PRUEBA MATERIAL DE CADA CRITERIO](#)
 - [14. Cómo funcionan los laboratorios](#)
 - [15. Preparación](#)
 - [16. CRITERIO 1 — El DID y su DID Document se generan en el dispositivo sin exponer la clave privada](#)
 - [17. CRITERIO 2 — El DID Document es conforme al modelo de datos de W3C DID v1.1](#)
 - [18. CRITERIO 3 — `authentication` y `assertionMethod` apuntan a la clave Multikey del titular](#)
 - [19. CRITERIO 4 — El documento queda almacenado de forma no exportable y asociado a la instancia](#)
 - [20. Publicación opcional: el DID del titular en el registro](#)
 - [21. Pruebas automáticas y recorrido de extremo a extremo](#)
- [PARTE V — PREGUNTAS Y RESPUESTAS](#)
 - [22. Preguntas sobre los conceptos](#)
 - [23. Preguntas por laboratorio y por criterio](#)
- [PARTE VI — CÓMO RESPONDER A CADA CRITERIO](#)
 - [24. Redacción modelo de las cuatro respuestas](#)
 - [25. Lista de comprobación para quien acepta](#)
- [PARTE VII — LÍMITES, HALLAZGOS Y OPERACIÓN](#)
 - [26. Lo que este informe NO demuestra, y lo que se encontró](#)
 - [27. Si algo no sale como en el informe](#)
 - [28. Operación diaria](#)
- [ANEXOS](#)
 - [Anexo A — Los scripts](#)
 - [Anexo B — Autocomprobación \(con respuestas\)](#)
 - [Anexo C — Ejercicios del método \(con respuesta modelo\)](#)

INFORME FINAL — ERSO 2026-003

Creación del DID y DID Document del titular

Manual de comprensión, construcción y comprobación

Proyecto	Identidad Digital Soberana SSI
ERSo	2026-003 — Creación del DID y DID Document del titular
Desarrollador asignado (según la ERSo)	Luis González
Plantilla de pruebas y pruebas funcionales (según la ERSo)	Geovani Rincón
Fechas de la ERSo	Elaboración: viernes 18-sep-2026 · Desarrollo: viernes 25-sep-2026, 7:30 a. m. · Prueba: miércoles 30-sep-2026, 7:30 a. m.
Dominio del laboratorio	civica-desarrollo.avance.org.co
Ubicación del proyecto	/home/geovani/Descargas/generic/bitacora/new_proyect
Salidas de terminal de este informe	Obtenidas ejecutando los comandos reales sobre el proyecto, el 1 de octubre de 2026
Complementos	scripts/lab-003-completo.sh · informes/ERSo-2026-003.md (versión corta) · informes finales de las ERSo 001, 004-008

Nota de fechas. El desarrollo (25-sep) y la prueba (30-sep) son anteriores a la fecha de este informe (1-oct-2026). El documento sirve para repetir la prueba o dejar constancia; las firmas de la tabla de actividades son de las personas responsables.

Lo más importante que debes saber antes de empezar. (1) Igual que en la ERSo 001, **no hay hardware seguro real**: la clave «nace en el custodio» simulado y el almacén sellado usa una clave interna del simulador. (2) Esta ERSo **toca la privacidad**: el diagrama de arquitectura del equipo indica que el Wallet Backend publica el DID del titular en el registro público, lo que contradice el principio de «no publicar un DID por ciudadano» de las ERSo 004-008. El informe explica la decisión y sus mitigaciones en §26. (3) El PDF de la ERSo lista el **criterio 1 dos veces** (primera y última fila); se trató como uno solo.

Cómo leer este informe

Símbolo	Significa
💡	Idea clave: lo más importante de la sección, en una frase
🔍	Qué vas a ver: lo que debes esperar <i>antes</i> de ejecutar un comando

Símbolo	Significa
✓	Qué significa: cómo interpretar lo que el sistema respondió
⚠	Cuidado: una trampa frecuente o un límite que conviene conocer
🔧	Predice antes de ejecutar: una pregunta para que pienses antes de ver el resultado

Si eres...	Lee esto
Quien decide o aprueba	El Resumen ejecutivo y la Parte VII (sobre todo la decisión de privacidad)
Quien necesita entender el problema	Parte I y Parte II
Quien debe reproducir y comprobar	Partes III y IV
Quien prepara la prueba funcional	Partes IV, VI y la lista de comprobación (§25)
Quien prepara una exposición	Partes V y VI

Cómo están presentados los comandos. Los bloques `console` son una **sesión de terminal real**: las líneas con `$` son lo que se escribe; las demás, lo que el sistema respondió. Los valores que cambian en cada ejecución (identificadores, claves, huellas, tokens) serán distintos al repetir; lo que debe coincidir es el **patrón**.

Un recurso de este informe: «el recorrido». Se añadió al simulador del titular (`holder-sim`) el comando `scenario tour-did`, que ejecuta el flujo completo **imprimiendo cada resultado**: el registro de generación, el documento, el informe de conformidad con sus 10 comprobaciones, el archivo sellado en disco y sus intentos de apertura indebida. No cambia nada del producto; solo muestra.

Contenido

Parte	Secciones	De qué trata
Resumen ejecutivo	—	El problema, la solución y el resultado en una página
I · Marco conceptual	1 a 4	Los términos, en lenguaje sencillo, y el método de trabajo
II · Qué pide la ERSO	5 a 10	Capacidades, condiciones, descripción, pasos y criterios, frase por frase
III · El proyecto	11 a 13	Qué se construyó, cómo se monta en Docker y cómo funciona por dentro
IV · Laboratorios	14 a 21	La prueba material de cada criterio, con cada comando y su respuesta
V · Preguntas y respuestas	22 y 23	Todas las preguntas de comprensión con su respuesta
VI · Cómo responder	24 y 25	Redacción modelo de cada criterio y lista de comprobación
VII · Límites y operación	26 a 28	Lo que NO se demuestra, qué hacer si algo falla y operación diaria

Parte	Secciones	De qué trata
Anexos	A a D	Scripts, autocomprobación, ejercicios y referencias

Resumen ejecutivo

El problema. Para participar en el ecosistema, la persona necesita un **identificador propio** que ella controle, sin depender de que un registro central se lo conceda: su **DID**, y un **documento público** (el *DID Document*) que diga cuál es su clave pública y para qué sirve. Las dificultades:

1. El DID y el documento deben **generarse en el propio dispositivo** del titular, con una clave que nunca salga.
2. El documento debe **ser correcto**: conforme al modelo de datos de W3C, sin claves privadas ni datos civiles ni extensiones propias.
3. Debe **guardarse** en el dispositivo de forma que no se pueda exportar ni mover a otro.
4. **Poseer la clave** demuestra la capacidad de usarla; **no acredita** nombre, nacionalidad ni edad. El DID no prueba que el dispositivo pertenezca a una persona civil concreta.

La solución.

- `HolderDidService` (en la cartera): pide al custodio una clave nueva, **deriva el DID de la huella de la clave pública**, construye el documento con la clave en Multikey, **valida la conformidad antes de entregarlo** (10 comprobaciones con referencia a la norma) y deja un **registro de generación**.
- `SealedDocumentStore`: guarda el documento **cifrado** con una clave interna del custodio, ligado a la instancia y al DID.
- Publicación **opcional** vía Wallet Backend → VDR. El backend **no puede firmar por el titular**: reenvía el desafío del VDR y es el dispositivo quien firma.

El resultado.

#	Criterio	Resultado	Dónde
1	DID y documento generados en el dispositivo sin exponer la clave privada	✓ (custodio simulado ⚠)	§16
2	Documento conforme al modelo de datos de W3C DIDs v1.1	✓ estructural ⚠	§17
3	<code>authentication</code> y <code>assertionMethod</code> apuntan a la clave Multikey del titular	✓	§18
4	Documento almacenado de forma no exportable y asociado a la instancia	✓ (almacén simulado ⚠)	§19

Cifras: 25 pruebas automáticas propias (15 + 10, todas en verde); 10 comprobaciones de conformidad con su referencia; 7 documentos defectuosos detectados por el informe (más el original, que pasa); 3 intentos de abrir el archivo sellado indebidamente, los 3 rechazados; 18 formas textuales de claves privadas buscadas en el volcado de toda la base (backend + registro) con **0 coincidencias**.

Lo que debes saber de antemano: (1) el hardware es simulado; (2) «conforme» es **estructural**, no la suite oficial de W3C; (3) la publicación del DID de ciudadanos **permite correlación** (§26); (4) solo se implementó la **creación**, no la rotación ni la desactivación del DID del titular.

PARTE I — MARCO CONCEPTUAL: los términos que necesitas

1. La historia en cinco minutos

Piensa en un **sello personal** que cada ciudadano fabrica por sí mismo, dentro de una caja fuerte portátil (ERSo 001). Del sello se deriva una **dirección** («su domicilio digital») y una **ficha pública** que dice: «mi sello es este y sirve para identificarme y para firmar».

- El **domicilio** (el DID) se calcula a partir del sello: nadie puede reclamarlo sin tenerlo.
- La **ficha** (el DID Document) solo contiene lo público: la forma de verificar el sello. **Nada** secreto, **nada** del nombre ni de la edad.
- Antes de entregar la ficha, el ciudadano la hace **revisar** con una lista de 10 comprobaciones. Si alguna falla, **no se entrega**.
- La ficha se guarda en la caja del teléfono, **cerrada con una llave que no sale** de él. Si alguien copia el archivo a otro teléfono, no lo puede abrir.
- Si el ciudadano **quiere** que otros puedan encontrar su ficha, puede pedir al servidor que la **publique** en un registro público. Pero el servidor no puede firmar en su nombre: es el teléfono quien firma.

💡 Esta ERSo trata de que **el titular tenga su propia identidad técnica, nacida en su dispositivo, correcta y bien guardada** —y de entender que eso, por sí solo, **no dice quién es** la persona.

2. Diccionario de términos

2.1 DID y su documento

Término	En palabras sencillas
DID	Identificador descentralizado, <code>did:web:dominio:ruta</code> : una dirección que la persona controla sin pedir permiso a un registro central.
<code>did:web</code>	Método de DID donde el identificador se convierte en una URL: <code>did:web:ejemplo.org:titulares:XYZ</code> → <code>https://ejemplo.org/titulares/XYZ/did.json</code> .
DID Document	El JSON público de un DID: su <code>id</code> , claves públicas y para qué sirven.
<code>verificationMethod</code>	La lista de claves públicas del documento.
<code>authentication</code>	Relación: la clave sirve para demostrar quién eres (responder un desafío).
<code>assertionMethod</code>	Relación: la clave sirve para afirmar (firmar credenciales/afirmaciones).
<code>controller</code>	Quién gobierna el documento. Aquí, el propio DID.
Multikey / multibase	Forma estándar de escribir una clave pública como texto. Las P-256 empiezan por <code>zDn...</code> (<code>z</code> = base58btc).

Término	En palabras sencillas
Huella RFC 7638 (thumbprint)	Resumen estable de una clave pública. Aquí es el identificador del titular.
Derivar	Calcular el DID a partir de la clave pública: determinista, sin pedirlo a nadie.
Registro de generación	La anotación de cómo nació la clave: nivel, origen, no exportable, cuándo, qué custodio.

2.2 Conformidad

Término	En palabras sencillas
W3C DID v1.1	La especificación del modelo de datos de los DID.
Conforme (estructural)	El documento tiene la forma que exige el modelo de datos. No es la suite oficial de pruebas de W3C.
Informe de conformidad	Lista de comprobaciones (aquí 10, C01 – C10), cada una con su requisito y su referencia a la norma, y si pasó o no.
Extensión propietaria	Una propiedad inventada fuera del modelo estándar. Está prohibida.
Datos civiles	Nombre, documento, fecha de nacimiento... No pueden aparecer en el documento.
Requisito previo	La validación va antes de cualquier publicación.

2.3 Almacenamiento no exportable

Término	En palabras sencillas
Sellar	Cifrar el documento con una clave interna del custodio.
AES-GCM	Un cifrado que además detecta alteraciones .
AAD (datos autenticados adicionales)	Datos (aquí: la instancia y el DID) que no se cifran pero se atan al cifrado: si cambian, el archivo no se abre.
Almacén sellado	El archivo .wds en el dispositivo: solo texto cifrado.
Respaldo cifrado	Una copia del documento, cifrada por el custodio, que el backend guarda sin poder leerla .

2.4 Publicación y privacidad

Término	En palabras sencillas
VDR	El registro que guarda y sirve DID Documents (ERSo 004).
Wallet Backend	El servidor de la cartera; aquí actúa como mensajero : pide el desafío al VDR y entrega la firma del dispositivo.
Prueba de posesión	Firma del desafío del VDR con la clave del DID: demuestra que quien publica controla el DID.
Namespace comodín titulares/*	Espacio reservado al Wallet Backend para los DID de los titulares.

Término	En palabras sencillas
Correlación	Reconocer a la misma persona en contextos distintos por un identificador fijo y público. Es el riesgo de privacidad de publicar DID de ciudadanos.
Documento huérfano	Un DID publicado cuya clave se perdió: no se puede actualizar ni desactivar.

3. Las siete ideas madre

1. **La creación es local.** Un DID no necesita un registro para existir.
2. **El DID sale de la clave.** Nadie lo puede reclamar sin ella.
3. **El documento solo contiene lo público.**
4. **Se valida antes de entregar.** Si no es conforme, la clave se borra y el DID no se entrega.
5. **El archivo guardado está sellado** y atado a su instancia.
6. **El servidor no firma por el titular:** solo transmite lo que el dispositivo firmó.
7. **Poseer la clave no acredita quién eres.**

4. El método de trabajo: cómo se piensa un criterio

1. **Descomponer** el criterio en el verbo y la evidencia.
 2. **Hacerlo comprobable.**
 3. **Buscar el caso negativo.**
 4. **Predecir.**
 5. **Ejecutar y observar.**
 6. **Correlacionar** con la regla del código.
 7. **Redactar** la respuesta con la evidencia **y con el límite.**
-

PARTE II — QUÉ PIDE LA ERSO 003, EXPLICADO FRASE POR FRASE

5. La ficha del documento

Campo del PDF	Valor
Proyecto	Identidad Digital Soberana SSI
Título	Creación del DID y DID Document del titular
Desarrollador	Luis González
Fecha de la ERSO	Viernes, 18 de septiembre de 2026
Fecha de desarrollo	Viernes, 25 de septiembre de 2026, 7:30 a. m.
Fecha de prueba	Miércoles, 30 de septiembre de 2026, 7:30 a. m.
Responsables	Análisis y diseño: Karen Flórez Madiedo · Asignar desarrollador, aceptar archivos y archivo: Rocío Villamizar · Implementar: Luis González · Plantilla de pruebas y pruebas funcionales: Geovani Rincón

⚠ Las firmas y fechas de la tabla de actividades **corresponden a las personas responsables**; este informe aporta las **evidencias técnicas**, no las firmas.

Capacidades → Condiciones → Descripción → Qué debe hacer (6 pasos) → Criterios (4*) → Actividades

* El PDF lista el criterio 1 dos veces; se trata como uno solo.

6. Capacidades del proceso

6.1 La frase principal, desarmada

"Se requiere habilitar, en la **cartera del ciudadano**, la **generación local del identificador descentralizado (DID)** del titular y la **construcción de su DID Document** asociado, con el **método adoptado**, **sin exponer la clave privada** y **sin depender de un registro centralizado obligatorio**."

#	Fragmento	En lenguaje sencillo	Cómo se materializó
1	"en la cartera del ciudadano"	Ocurre en el dispositivo	HolderDidService (biblioteca de la cartera)

#	Fragmento	En lenguaje sencillo	Cómo se materializó
2	"generación local del DID"	El identificador se calcula allí	DidWeb.of(dominio, ["titulares", huella])
3	"construcción del DID Document"	Armar la ficha pública	DidDocumentBuilder.build
4	"con el método adoptado"	did:web (decisión del laboratorio)	Adaptador DidMethodAdapter
5	"sin exponer la clave privada"	La privada no sale	KeyCustodian (ERSo 001)
6	"sin depender de un registro centralizado obligatorio"	Crear no exige publicar	Prueba con el VDR apagado

6.2 Las seis capacidades

#	Capacidad (texto del PDF)	Qué se busca	Cómo se resolvió	Paso
1	Generar el par de claves del titular dentro del entorno protegido	La clave nace en el custodio	KeyCustodian.generate con política de nivel mínimo	1
2	Derivar y registrar el identificador conforme al método DID adoptado	DID calculado y anotado	Huella RFC 7638 + GenerationRecord	2
3	Construir el DID Document con la clave pública en Multikey	Ficha con la clave	DidDocumentBuilder	3
4	Vincular authentication y assertionMethod a la clave pública	Para qué sirve la clave	Referencias a #key-1	4
5	Almacenar el documento y su material de claves de forma no exportable	Guardarlo sin que se pueda sacar	SealedDocumentStore	5
6	Validar la conformidad contra W3C DIDs v1.1	Revisar antes de entregar	DidConformance (10 comprobaciones)	6

7. Condiciones del proceso

Condición 1 — "La creación es local al titular; el backend no accede a la clave privada."

- **Qué significa.** Todo ocurre en el dispositivo; el servidor no interviene en la creación.
- **Qué problema evita.** Que un fallo del servidor comprometa la identidad de los titulares.
- **Cómo se cumple.** La creación solo usa el custodio; la búsqueda de claves privadas en toda la base da 0 (§16).

Condición 2 — "El documento se construye conforme a W3C DIDs v1.1 y no introduce extensiones propietarias."

- **Qué significa.** Solo propiedades del modelo estándar.
- **Qué problema evita.** Documentos que solo entiende un fabricante.
- **Cómo se cumple.** Comprobación C10 (§17).

Condición 3 — "El método DID es el definido en el laboratorio; no se integran anclajes equivalentes a ION."

- **Qué significa.** `did:web`; sin cadenas de bloques.
- **Qué problema evita.** Complejidad innecesaria.
- **Cómo se cumple.** Solo se deriva `did:web`.

Condición 4 — "El DID Document no incluye claves privadas, credenciales personales ni datos civiles."

- **Qué significa.** Solo material público.
- **Cómo se cumple.** `C08` y `C09` (§17).

Condición 5 — "La validación de conformidad es requisito previo a cualquier publicación."

- **Qué significa.** Primero revisar, luego entregar/publicar.
- **Qué problema evita.** Publicar documentos defectuosos.
- **Cómo se cumple.** Si la validación falla, la clave se borra y el DID no se entrega; el backend la **repite** antes de tocar el registro (§17, §20).

8. Descripción del proceso

"Un DID es un identificador que un sujeto controla sin depender de un registro central, y su DID Document describe el material público de verificación y para qué se usa cada clave."

Resume los dos objetos: **el identificador** y **la ficha**.

"Importante: poseer la clave demuestra la capacidad de usar esa clave, no acredita por sí solo nombre, nacionalidad ni edad, y el DID del titular no prueba que el dispositivo pertenezca a una persona civil concreta."

La advertencia clave: **identidad técnica** $\neq$ **identidad civil**. Lo segundo lo aportan las credenciales emitidas por una entidad (ERSo 002).

"Literatura y temas a consultar"

Lectura	Qué te aporta
W3C DIDs v1.1	El modelo de datos
Método <code>did:web</code>	La regla DID → URL
Multikey / multibase	La codificación de la clave pública
Ejemplos de DID Document con authentication y assertionMethod	Cómo se ve un documento correcto

9. Qué debe hacer: los seis pasos

1. Generar el par de claves del titular dentro del entorno protegido del dispositivo.
2. Derivar y registrar el identificador del titular conforme al método DID adoptado por el laboratorio.
3. Construir el DID Document con la clave pública del titular en representación Multikey.
4. Vincular las relaciones de verificación (authentication, assertionMethod) a la clave pública del titular.
5. Almacenar el documento localmente y asociarlo a la instancia de cartera, sin exportar el material de claves.
6. Ejecutar la validación de conformidad estructural contra el modelo de datos de W3C DIDs v1.1 y registrar el resultado.

Paso	Lo que pide	Criterio que lo comprueba	Laboratorio
1	Generar la clave	Criterio 1	§16
2	Derivar y registrar el identificador	Criterio 1	§16
3	Construir el documento con Multikey	Criterios 2 y 3	§17, §18
4	Vincular las relaciones	Criterio 3	§18
5	Almacenar sin exportar	Criterio 4	§19
6	Validar la conformidad	Criterio 2	§17

10. Los cuatro criterios de aceptación

1. El DID y su DID Document se generan en el dispositivo sin exponer la clave privada; evidencia: registro de generación. **2.** El DID Document es conforme al modelo de datos de W3C DIDs v1.1; evidencia: informe de conformidad. **3.** Las relaciones de verificación (authentication, assertionMethod) apuntan a la clave pública Multikey del titular; evidencia: documento generado. **4.** El documento queda almacenado de forma no exportable y asociado a la instancia de cartera; evidencia: prueba de almacenamiento.

Criterio	Verbo y evidencia	Lo que debo poder mostrar	El caso negativo	Mecanismo
1	Se generan sin exponer · registro de generación	Registro con origen GENERATED y no exportable; ninguna clave privada en ningún lado	Búsqueda de claves privadas en toda la base	Custodio + registro
2	Es conforme · informe	10 de 10 comprobaciones	Documentos defectuosos detectados	DidConformance
3	Apuntan · documento	authentication y assertionMethod → #key-1, que es la Multikey del titular	assertionMethod vacío; clave inexistente	Comprobación C07

Criterio	Verbo y evidencia	Lo que debo poder mostrar	El caso negativo	Mecanismo
4	Almacenado no exportable · prueba de almacenamiento	Archivo sin texto en claro; no abre en otro dispositivo/instancia	Alterar un byte	SealedDocumentStore

PARTE III — EL PROYECTO: QUÉ SE CONSTRUYÓ PARA ESTA ERSO Y CÓMO ESTÁ MONTADO

11. Visión general

11.1 Qué se construyó

Pieza	Dónde corre	Qué hace
HolderDidService (wallet-core)	En el dispositivo (biblioteca)	Orquesta: clave → DID → documento → conformidad → registro de generación
DidConformance (did-core)	Biblioteca	Informe de conformidad estructural (10 comprobaciones)
SealedDocumentStore (wallet-core)	En el dispositivo	Guarda el documento sellado y atado a la instancia
Publicación (wallet-service)	Contenedor wallet	Valida de nuevo y gestiona el desafío del VDR; reenvía la firma del dispositivo
VDR (vdr-service)	Contenedor vdr	Publica y sirve el DID (ERSo 004-008)
Holder App simulada	Contenedor holder	Hace de teléfono

11.2 Las piezas en Docker

Contenedor	Para qué sirve en esta ERSO
nginx	Puerta 8444 (cartera) y 8443 (lectura pública del DID)
wallet	Backend: valida y media la publicación
vdr	Registro: recibe la escritura del Wallet Backend y la confirma leyendo su URL
postgres	wallet_did_publications, wallet_did_backups, y las tablas del VDR
holder	El teléfono simulado

```
$ docker compose ps --format 'table {{.Service}}\t{{.Status}}\t{{.Ports}}'
SERVICE      STATUS      PORTS
credential    Up 3 minutes
nginx          Up 3 minutes      80/tcp, 0.0.0.0:8444->8444/tcp, [::]:8444->8444/tcp,
0.0.0.0:8443->443/tcp, [::]:8443->443/tcp, 0.0.0.0:9443->8443/tcp, [::]:9443->8443/tcp
postgres       Up 3 minutes (healthy)  5432/tcp
vdr            Up 3 minutes
wallet         Up 3 minutes
```

11.3 El recorrido de la creación y la publicación

```
EN EL DISPOSITIVO (sin red)                                EN EL SERVIDOR (opcional)
1. el custodio GENERA el par de claves (nivel ≥ el de la cartera)
2. thumbprint(clave pública) → DID = did:web:<dominio>:titulares:<huella>
3. DidDocumentBuilder → documento con la clave en Multikey, authentication y assertionMethod → #key-1
4. DidConformance.check → 10 comprobaciones. ¿alguna falla? → se BORRA la clave y NO se entrega el DID
5. registro de generación (nivel, origen, exportable=false, custodio)
6. SealedDocumentStore.save → archivo .wds cifrado, atado a instancia + DID
-----
- - - - -
(si el titular quiere publicar)
7. POST /instances/{id}/did {documento} → valida otra vez (conformidad, namespace titulares/<huella>, nivel de clave)
8.                                     pide el desafío al VDR
9. ← {payload a firmar: aud, challenge, did, docHash, purpose}
10. el custodio firma con la clave del DID
11. POST ../did/{publicationId}/proof {firma} → PUT al VDR (If-Match: 0); el VDR confirma leyendo su URL pública
12. ← PUBLISHED, versión 1, URL pública
```

💡 Los pasos 1 a 6 **no necesitan red ni registro**. El servidor entra solo desde el 7, y **nunca** firma por el titular.

12. El entorno para esta ERSO

12.1 Preparar el terminal

Atajo	Qué hace
WALLET <escenario>	Ejecuta un escenario del teléfono contra el servidor real
PSQL	Entra a la base de datos
PUB	Opciones de <code>curl</code> hacia la lectura pública (8443)

```
$ cd /home/geovani/Descargas/generic/bitacora/new_proyect/deploy
$ set -a; . ./env; set +a; export LOCAL_UID=$(id -u) LOCAL_GID=$(id -g)
$ D=$VDR_DOMAIN
$ W=./evidencias/work
$ BASE=https://$D:8444
$ PUB="--cacert certs/ca.crt --resolve $D:8443:127.0.0.1"
$ CW="--cacert certs/ca.crt --resolve $D:8444:127.0.0.1"
$ PSQL="docker compose exec -T postgres psql -U $POSTGRES_USER -d $POSTGRES_DB"
$ H() { docker compose --progress quiet --profile tools run --rm -T holder "$@"; }
$ WALLET() { H escenario "$1" --authority authority.json --domain $D --base $BASE --ca /certs/ca.crt "${@:2}"; }
$ CRED() { H escenario "$1" --authority authority.json --domain $D --base $BASE --ca /certs/ca.crt --admin-url https://$D:8443 --p12 /certs/vdr-admin.p12 --p12-pass $P12_PASS --admin-token $CREDENTIAL_ADMIN_TOKEN "${@:2}"; }
```

12.2 La regla que deriva el identificador (en el código)

```
$ sed -n '/Derivación del identificador/,/^ \*\//p' ../wallet-core/src/main/kotlin/co/org/avance/ssi/wallet/core/HolderDid.kt | cut -c1-220
* Derivación del identificador (decisión del proyecto, para did:web): `did:web:<dominio>:titulares:<huella RFC 7638 de la clave pública>`.
* Es determinista, no contiene datos civiles y no se puede colisionar sin la clave. Requiere
```

```
publicarse en el VDR solo si se
* quiere que sea resoluble públicamente; la creación en sí es local y no depende de ningún registro.
*/
```

- **Qué significa.** `did:web:<dominio>:titulares:<huella RFC 7638>`. Es **determinista, no lleva datos civiles y no se puede colisionar** sin la clave. `did:web` no define derivación; esta es la regla del proyecto.

12.3 El espacio reservado para los titulares

```
$ echo "select path, owner_client_id from namespaces where owner_client_id='wallet-backend' order by 1 limit 3" | $PSQL
      path                                     | owner_client_id
-----+-----
titulares/*                                | wallet-backend
titulares/WI-RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmDHw6w | wallet-backend
titulares/ZYADlbbanWtGyE1F6RzAXrr-cEggJgTwFnnsXE7cK_E | wallet-backend
(3 rows)
```

- `titulares/*` es un **comodín de un nivel** (ERSo 004) reservado a `wallet-backend`. Cada titular publicado materializa su propia fila `titulares/<huella>`.
- **Observa** que el Wallet Backend no puede publicar fuera de `titulares/...`.

12.4 La tabla de publicaciones

```
$ echo "\d wallet_did_publications" | $PSQL | sed -n 1,20p
Table "public.wallet_did_publications"
  Column      |      Type      | Collation | Nullable | Default
-----+-----+-----+-----+-----
id            | uuid           |           | not null |
instance_id  | uuid           |           | not null |
did          | text           |           | not null |
doc_hash     | text           |           | not null |
document     | jsonb          |           | not null |
key_level    | text           |           | not null |
vdr_challenge_id | text          |           | not null |
vdr_nonce    | text           |           | not null |
vdr_audience | text           |           | not null |
status       | text           |           | not null |
vdr_version  | integer        |           |          |
public_url   | text           |           |          |
failure      | text           |           |          |
created_at   | timestamp with time zone |           | not null | now()
completed_at | timestamp with time zone |           |          |
Indexes:
    "wallet_did_publications_pkey" PRIMARY KEY, btree (id)
```

Cada publicación guarda el DID, el hash del documento, el **nivel de la clave**, los datos del desafío del VDR, el estado y la URL pública resultante.

13. Mapa de requisitos a implementación

Paso	Implementación	Dónde
1 · Clave en el entorno protegido	<code>HolderDidService.create</code> → <code>KeyCustodian.generate</code> (política de nivel mínimo, con attestation si hay desafío)	<code>wallet-core/.../HolderDid.kt</code>

Paso	Implementación	Dónde
2 · Derivar y registrar el identificador	<code>DidWeb.of(dominio, ["titulares", huella]);</code> <code>GenerationRecord</code>	<code>HolderDid.kt</code>
3 · Documento con Multikey	<code>DidDocumentBuilder.build</code> (el mismo de las ERSO 005/006)	<code>did-core</code>
4 · Vincular relaciones	El constructor las apunta a <code>did#key-1</code> ; comprobación C07	<code>DidConformance</code>
5 · Almacenar sin exportar	<code>SealedDocumentStore</code> : cifrado con clave interna del custodio; instancia y DID como AAD	<code>SealedDocumentStore.kt</code>
6 · Validar conformidad	<code>DidConformance.check</code> → <code>ConformanceReport</code> ; si falla, la clave se borra; el backend la repite	<code>DidConformance.kt</code> , <code>WalletService.beginDid</code>

PARTE IV — LABORATORIOS DE DEMOSTRACIÓN: LA PRUEBA MATERIAL DE CADA CRITERIO

14. Cómo funcionan los laboratorios

Cada laboratorio:  **predicción** → **comandos** (con su respuesta real y su explicación) →  **conclusión**.

El laboratorio central es **el recorrido** (`WALLET tour-did`): se ejecuta **una vez** (laboratorio A) y su salida se reparte entre los criterios. Al comienzo de cada bloque verás el mismo comando, con un comentario `# ...` (extracto...) que indica qué sección se muestra.

Lab	Criterio	Qué se prueba	Sección
A	1	Generación local sin exponer la clave privada	§16
A	2	Informe de conformidad	§17
A	3	Relaciones → clave Multikey	§18
A	4	Almacenamiento no exportable	§19
B-D	—	Publicación, resolución y compuertas del backend	§20
E	—	Pruebas automáticas y recorrido de extremo a extremo	§21

15. Preparación

Ver §12.1. El recorrido crea una cartera (ERSo 001), crea el DID, lo publica y lo resuelve; al final imprime `DID=...`, que el terminal guarda en `DIDT` y la huella en `TH` para los laboratorios siguientes.

16. CRITERIO 1 — El DID y su DID Document se generan en el dispositivo sin exponer la clave privada

Criterio. "El DID y su DID Document se generan en el dispositivo sin exponer la clave privada; evidencia: registro de generación."

 **Predice antes de ejecutar**

(1) ¿De dónde sale el identificador del titular? (2) Si buscamos las claves privadas de prueba en el volcado completo de la base (backend y registro), ¿cuántas coincidencias esperas?

16.1 El recorrido

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 1; el resto del recorrido se muestra en las demás secciones)
— 1. Registro de generación (ERSo 003, criterio 1)
{
  "did": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
  "keyAlias": "holder-23100989953880",
  "publicKeyMultibase": "zDnaemq2FP8eCk72Vtt5ufijAMnv7g8mQLR8qWKRtvD84Zo5K",
  "thumbprint": "Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
  "protectionLevel": "TEE",
  "keyOrigin": "GENERATED",
  "exportable": false,
  "custodian": "dispositivo-simulado-tee",
  "conformant": true,
  "generatedAt": "2026-10-01T19:16:52.784643333Z"
}
```

- **Qué hace.** Muestra el **registro de generación** (GenerationRecord).
- **Qué significa.** Cada campo es una afirmación comprobable:

Campo	Valor	Significa
did	did:web:...:titulares:ZYADlb...	El identificador del titular
publicKeyMultibase	zDnae...	Solo la clave pública
thumbprint	ZYADlb...	La huella; es la última parte del DID
protectionLevel	TEE	Nivel de la clave (verificado en la ERSo 001)
keyOrigin	GENERATED	Nació dentro del custodio
exportable	false	No exportable
custodian	dispositivo-simulado-tee	Quién la custodia
conformant	true	Pasó las 10 comprobaciones (§17)
generatedAt	instante	Cuándo

No hay ningún campo con material privado.

16.2 De dónde sale el identificador

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 2; el resto del recorrido se muestra en las demás secciones)
— 2. DID derivado de la clave pública
  did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng
```

Respuesta a la predicción (1): `did:web:<dominio>:titulares:<huella>`. La **huella** de la clave pública es la última parte. El DID **no contiene** nombre ni documento: nada civil. Quien no tenga la clave no puede reclamarlo.

16.3 El mismo recorrido, ya completo: el registro de generación no contiene la clave privada

La prueba automática `WalletCoreTest > 003-C1` el DID se genera en el dispositivo sin exponer la clave privada (registro de generacion) serializa el registro y el documento y busca **formas textuales** de la clave privada real (decimal, hexadecimal, base64...): no aparece ninguna.

16.4 La prueba definitiva: buscar las claves en toda la base

```
$ docker compose exec -T postgres pg_dump -U $POSTGRES_USER $POSTGRES_DB > $W/dump.sql
$ echo "control: el volcado contiene la publicación -> $(grep -c 'DID_PUBLISHED' $W/dump.sql) líneas"
$ echo "formas de claves privadas de prueba buscadas: $(wc -l < $W/secrets-did.txt)"
$ echo "coincidencias en todo el volcado (backend + VDR): $(grep -c -F -f $W/secrets-did.txt $W/dump.sql)"
$ rm -f $W/dump.sql
control: el volcado contiene la publicación -> 3 líneas
formas de claves privadas de prueba buscadas: 18
coincidencias en todo el volcado (backend + VDR): 0
```

- **Qué hace.**
 1. El recorrido guardó **18 formas textuales** de las claves privadas reales usadas (de tres dispositivos).
 2. `pg_dump` vuelca **toda** la base: tablas de la cartera (`wallet_*`) y del registro (`did_documents`, `did_document_versions`, `operations`, `audit_log`...).
 3. `grep -c -F -f` cuenta las coincidencias.
- **Qué significa.** El **control** (`DID_PUBLISHED` aparece) demuestra que el volcado contiene la publicación. **0 coincidencias:** ni el backend ni el registro llegaron a ver una clave privada. Respuesta a la predicción (2).

🎯 Conclusión — evidencia del criterio 1

Evidencia	Resultado
Registro de generación con <code>GENERATED</code> , <code>exportable:false</code>	✓
DID derivado de la huella de la clave pública	✓
Sin material privado en el registro ni en el documento	✓
18 formas de claves privadas buscadas en toda la base	✓ 0 coincidencias
Prueba en un chip real	⚠ pendiente (§26)

17. CRITERIO 2 — El DID Document es conforme al modelo de datos de W3C DIDs v1.1

Criterio. "El DID Document es conforme al modelo de datos de W3C DIDs v1.1; evidencia: informe de conformidad."

Predice antes de ejecutar

Se le hará una pequeña alteración a un documento correcto (añadirle una propiedad `privateKeyMultibase`, quitarle `@context`, cambiarle el `id`...). ¿Las 10 comprobaciones fallarán todas o cada defecto activará las suyas?

17.1 El informe de conformidad

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 4; el resto del recorrido se muestra en las demás secciones)
— 4. Informe de conformidad (criterio 2)
C01 CONFORME El 'id' es un DID sintácticamente válido y coincide con el DID esperado
    ref: DID Core §3.1 (sintaxis) y §5.1 (id)
C02 CONFORME El primer valor de @context es el contexto DID de W3C
    ref: DID Core §4.1 (@context)
C03 CONFORME Cada método de verificación tiene id (URL DID con fragmento del propio documento),
type y controller
    ref: DID Core §5.2 (verification methods)
C04 CONFORME Cada clave es Multikey con clave pública P-256 válida (multibase 'z', multicodec
0x1200)
    ref: Controlled Identifiers: Multikey
C05 CONFORME Los controladores son el propio DID (sin controladores ajenos)
    ref: DID Core §5.1.2 (controller)
C06 CONFORME Las relaciones de verificación son arreglos que referencian métodos existentes, y
hay al menos una clave en authentication
    ref: DID Core §5.3 (verification relationships)
C07 CONFORME authentication y assertionMethod apuntan a la clave pública Multikey del titular
    ref: ERSO 003 criterio 3; DID Core §5.3
C08 CONFORME El documento no contiene material de clave privada
    ref: ERSO 003 (condición del proceso)
C09 CONFORME El documento no contiene credenciales personales ni datos civiles
    ref: ERSO 003 (condición del proceso)
C10 CONFORME Solo propiedades registradas del modelo de datos DID: sin extensiones propietarias
    ref: DID Core §4 y DID Spec Registries
→ conformes: 10 de 10
```

✓ **Cómo leerlo.** Cada fila: **identificador**, **estado**, **requisito** y **referencia a la norma**. Las diez:

#	Qué comprueba
C01	id válido y coincide con el DID esperado
C02	El primer @context es el de DID de W3C
C03	Cada método de verificación tiene id (URL DID con fragmento propio), type y controller
C04	Cada clave es Multikey P-256 válida
C05	Los controladores son el propio DID
C06	Las relaciones son arreglos que referencian métodos existentes y hay al menos una clave en authentication
C07	authentication y assertionMethod apuntan a la clave Multikey del titular
C08	Sin material de clave privada
C09	Sin credenciales ni datos civiles
C10	Solo propiedades registradas: sin extensiones propietarias

Resultado: **10 de 10 conformes**.

17.2 ¿El informe detecta defectos?

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 7; el resto del recorrido se muestra en las demás secciones)
— 7. El informe de conformidad detecta documentos defectuosos
documento original          -> fallan: ninguna
con clave privada           -> fallan: C08, C10
con datos civiles           -> fallan: C09, C10
con extensión propietaria   -> fallan: C10
sin @context                -> fallan: C02
id ajeno                    -> fallan: C01, C03, C05
authentication a clave inexistente -> fallan: C06, C07
assertionMethod vacío        -> fallan: C07
```

- **Qué hace.** Aplica 7 alteraciones al documento correcto y ejecuta el informe sobre cada una.
- **Qué significa.** Cada defecto activa **las comprobaciones que le corresponden**, no todas:

Alteración	Comprobaciones que fallan
Original	ninguna
Con clave privada	C08 (secreto) y C10 (propiedad desconocida)
Con datos civiles	C09 y C10
Con extensión propietaria	C10
Sin @context	C02
id ajeno	C01, C03, C05
authentication a clave inexistente	C06, C07
assertionMethod vacío	C07

Respuesta a la predicción: no fallan todas; cada comprobación tiene su dominio.

17.3 La validación como requisito previo

La prueba 003 la validacion es un requisito previo - un documento no conforme no se entrega comprueba que, si el informe falla, HolderDidService **borra la clave y lanza** **DidNotConformantException**: el DID no sale del dispositivo. En el servidor, la misma validación se repite (§20.3).

Conclusión — evidencia del criterio 2

Evidencia	Resultado
Informe con 10 comprobaciones y referencias	✓ 10/10
Detecta 7 tipos de defecto	✓
Es requisito previo	✓
Es la suite oficial de W3C	⚠ no : conformidad <i>estructural</i> (§26)

18. CRITERIO 3 — authentication y assertionMethod apuntan a la clave Multikey del titular

Criterio. "Las relaciones de verificación (authentication, assertionMethod) apuntan a la clave pública Multikey del titular; evidencia: documento generado."

Predice antes de ejecutar

¿Qué debe valer authentication[0]? ¿Y con qué id de método de verificación debe coincidir?

18.1 El documento generado

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 3; el resto del recorrido se muestra en las demás secciones)
— 3. DID Document construido en el dispositivo (criterio 3: relaciones → clave Multikey)
{
  "@context": [
    "https://www.w3.org/ns/did/v1",
    "https://w3id.org/security/multikey/v1"
  ],
  "id": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
  "verificationMethod": [
    {
      "id": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1",
      "type": "Multikey",
      "controller": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
      "publicKeyMultibase": "zDnaemq2FP8eCk72Vtt5ufijAMnv7g8mQLR8qWkrTvD84Zo5K"
    }
  ],
  "authentication": [
    "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1"
  ],
  "assertionMethod": [
    "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1"
  ]
}
```

Cómo leerlo.

- verificationMethod[0].id = <DID>#key-1; type: Multikey; controller = el propio DID; publicKeyMultibase = zDnae... (**coincide** con la del registro de generación de §16.1).
- authentication = ["<DID>#key-1"].
- assertionMethod = ["<DID>#key-1"].
- No hay service, ni credentialSubject, ni ninguna otra propiedad.

Respuesta a la predicción: ambas relaciones valen <DID>#key-1, que es el id del único método de verificación.

18.2 La comprobación C07 lo verifica

La fila C07 del informe (§17.1) compara las referencias con **la clave pública que el custodio entregó**, no solo con la del documento. Y en §17.2 se ve que `assertionMethod` vacío y `authentication` a una clave inexistente la hacen fallar.

🎯 Conclusión — evidencia del criterio 3

`authentication` y `assertionMethod` apuntan a `#key-1`, cuya `publicKeyMultibase` es la Multikey P-256 del titular, y C07 lo comprueba.

19. CRITERIO 4 — El documento queda almacenado de forma no exportable y asociado a la instancia

Criterio. "El documento queda almacenado de forma no exportable y asociado a la instancia de cartera; evidencia: prueba de almacenamiento."

✏️ Predice antes de ejecutar

(1) Si abrimos el archivo guardado, ¿se podrá leer el DID? (2) Si lo copiamos a otro dispositivo, ¿se abre? (3) ¿Y si lo copiamos a otra instancia en el mismo dispositivo? (4) ¿Y si alteramos un solo byte?

19.1 El archivo y sus intentos de apertura

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 6; el resto del recorrido se muestra en las demás secciones)
— 6. Almacenamiento no exportable (criterio 4)
  archivo: 9b634545-91cf-4adc-a5bb-2dbf0a547524.wds (960 bytes)
  primeros 24 bytes (hex)           : 5744533128b178946c6b13175fe4f2b33f1ec2e841cf73a8
  ¿contiene el DID en claro?       : false
  ¿contiene 'verificationMethod'?  : false
  abrir con el custodio de ESTE dispositivo: DID true
  abrir con OTRO dispositivo        : rechazado: StoreAccessException
  abrir como OTRA instancia        : rechazado: StoreAccessException
  abrir con un byte alterado        : rechazado: StoreAccessException
```

✅ Cómo leerlo.

Comprobación	Resultado	Qué prueba
Archivo <instancia>.wds de 960 bytes	existe	El documento está asociado a la instancia (el nombre es el de la instancia)
Primeros bytes 57445331...	WDS1 (cabecera) + datos cifrados	Es binario cifrado
¿Contiene el DID en claro?	false	No se lee el contenido
¿Contiene verificationMethod ?	false	Idem

Comprobación	Resultado	Qué prueba
Abrir con el custodio de este dispositivo	recupera el DID	Solo el custodio correcto puede abrirlo
Abrir con otro dispositivo	StoreAccessException	No es exportable a otro aparato
Abrir como otra instancia	StoreAccessException	Está atado a su instancia (AAD)
Un byte alterado	StoreAccessException	AES-GCM detecta alteraciones

Respuesta a las predicciones: (1) no; (2) no; (3) no; (4) se detecta y se rechaza.

19.2 Por qué funciona

- El archivo se cifra con **AES-GCM** y una **clave interna del custodio** que no sale de él (`seal / unseal`).
- Como **datos autenticados (AAD)** se ligán la instancia y el DID: mover el archivo a otro lado cambia el AAD y el descifrado falla.
- Por eso «no exportable» aquí significa **no utilizable fuera de su dispositivo y de su instancia**.

Conclusión — evidencia del criterio 4

Evidencia	Resultado
Archivo cifrado, sin texto en claro	✓
Asociado a la instancia (nombre y AAD)	✓
No se abre con otro dispositivo, otra instancia, ni alterado	✓ 3 de 3
Prueba sobre Android real (EncryptedFile/Keystore)	⚠ pendiente (§26)

20. Publicación opcional: el DID del titular en el registro

Aunque la ERSO habla solo de la **creación local**, el diagrama de arquitectura del equipo añade la publicación opcional por el Wallet Backend. Se prueba aquí porque cierra el flujo y aprovecha las ERSO 004 a 008.

20.1 La publicación

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n
's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 5; el resto del recorrido se muestra en las demás secciones)
— 5. Publicación por el Wallet Backend en el VDR
HTTP 200
{
  "publicationId": "6c4969c9-e752-4805-b4b5-760558808f81",
  "did": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-
DCC2JiZRSa2ng",
  "status": "PUBLISHED",
  "version": 1,
  "publicUrl": "https://civica-desarrollo.avance.org.co/titulares/Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-
DCC2JiZRSa2ng/did.json",
  "vdrStatus": "CONFIRMED",
```

```
"hash": "sha256:08766cb4f5c134b48d89fe98732b5109d7fd962bcc6f9dc8cb73d03dbcf844a5"
}
```

- **Qué significa.** 200 y PUBLISHED, versión 1, con `vdrStatus: CONFIRMED` (el registro confirmó leyendo su URL pública) y el hash del documento.

20.2 Lo que ve cualquiera

```
$ curl -s $PUB https://$D:8443/titulares/$TH/did.json | jq .
{
  "@context": [
    "https://www.w3.org/ns/did/v1",
    "https://w3id.org/security/multikey/v1"
  ],
  "assertionMethod": [
    "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1"
  ],
  "authentication": [
    "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1"
  ],
  "id": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
  "verificationMethod": [
    {
      "controller": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng",
      "id": "did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng#key-1",
      "publicKeyMultibase": "zDnaemq2FP8eCk72Vtt5ufijAMnv7g8mQLR8qWkrTvD84Zo5K",
      "type": "Multikey"
    }
  ]
}
```

El documento servido por la URL pública es **el mismo** que se construyó en el dispositivo (la propia prueba lo comprueba comparando en forma canónica). Nada más.

20.3 El backend no puede publicar lo que no debe

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: secciones 9a, 9b; el resto del recorrido se muestra en las demás secciones)
— 9a. Publicar bajo el espacio de una entidad
HTTP 422
{
  "error": "DID_OUT_OF_NAMESPACE",
  "message": "El backend solo publica DID bajo did:web:civica-desarrollo.avance.org.co:titulares:
<huella>"
}

— 9b. Publicar un documento con datos civiles
HTTP 422
{
  "error": "DID_NOT_CONFORMANT",
  "message": "El documento no es conforme; no se publica",
  "details": [
    "C09: CIVIL_DATA: Campo de datos civiles no permitido en $.credentialSubject; CIVIL_DATA: Campo de datos civiles no permitido en $.credentialSubject.name",
    "C10: UNKNOWN_PROPERTY: Propiedad no permitida en el perfil de publicación: 'credentialSubject'"
  ]
}
```

```

}
}
· 3 claves privadas de prueba registradas en secrets-did.txt (solo laboratorio) para buscarlas en
la base de datos
DID=did:web:civica-desarrollo.avance.org.co:titulares:Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng
RESULTADO tour-did: 0 PASS · 0 FAIL

```

- **9a.** 422 DID_OUT_OF_NAMESPACE: el backend solo publica bajo `titulares/<huella>`; no puede usar el espacio de una entidad.
- **9b.** 422 DID_NOT_CONFORMANT: el documento con datos civiles **no llega** al VDR; la validación se repite en el servidor.

20.4 Lo que vio el registro

```

$ echo "select purpose, status, version, client_id, left(hash,26)||'...' as hash from operations where
did='$DIDT'" | $PSQL
$ echo "select action, actor from audit_log where did='$DIDT' order by id" | $PSQL

```

purpose	status	version	client_id	hash
CREATE	CONFIRMED	1	wallet-backend	sha256:08766cb4f5c134b48d8...

(1 row)

action	actor
CHALLENGE_ISSUED	wallet-backend
WRITE_CREATE	wallet-backend
PUBLICATION_CONFIRMED	system

(3 rows)

- La operación la hizo **wallet-backend**, no el titular: CHALLENGE_ISSUED → WRITE_CREATE → PUBLICATION_CONFIRMED.
- Pero la **prueba de posesión** que autorizó la escritura la firmó **el dispositivo** con la clave del DID; el backend solo la reenvió. Si hubiera intentado publicar sin ella, el registro habría rechazado la escritura (INVALID_PROOF, ERS0 008).

```

$ echo "select path, owner_client_id from namespaces where path='titulares/$TH'" | $PSQL

```

path	owner_client_id
titulares/Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng	wallet-backend

(1 row)

El namespace del titular (`titulares/<huella>`) quedó **materializado** bajo el comodín `titulares/*`, con dueño `wallet-backend`.

20.5 Lo que quedó en el backend

```

$ echo "select status, vdr_version as version, key_level as nivel, left(public_url,60)||'...' as url,
completed_at is not null as completada from wallet_did_publications order by created_at desc limit 2"
| $PSQL 2>&1
$ echo "select length(blob) as bytes_cifrados, left(encode(blob,'hex'),24)||'...' as inicio,
left(checksum,16)||'...' as checksum from wallet_did_backups order by updated_at desc limit 1" | $PSQL
2>&1

```

status	version	nivel	url
PUBLISHED	1	TEE	https://civica-desarrollo.avance.org.co/titulares/Gz8p4wBcA9...
PUBLISHED	1	TEE	https://civica-desarrollo.avance.org.co/titulares/ZYADlbbanW...

(2 rows)

bytes_cifrados	inicio	checksum
789	06033ac0dd471c2f21c7ca25...	sha256:e5944989d...

(1 row)

- **Publicaciones:** estado, versión, **nivel de la clave** (TEE : la clave del DID debe demostrar al menos el nivel de la cartera), URL pública y marca de completada.
- **Respaldo:** `wallet_did_backups` guarda **bytes cifrados** y un checksum. El backend **no puede leerlo**: solo el custodio lo abre.

20.6 Resolución pública

```
$ OUT=$(WALLET tour-did --secrets-out secrets-did.txt); echo "$OUT"; DIDT=$(echo "$OUT" | sed -n 's/^DID=//p'); TH=${DIDT##*:}
# ... (extracto del recorrido: sección 8; el resto del recorrido se muestra en las demás secciones)
— 8. Resolución pública y verificación con la clave del titular
    resuelto                : true
    metadatos                : ResolutionMetadata(error=null, message=null,
contentType=application/did+json, url=https://civica-
desarrollo.avance.org.co/titulares/Gz8p4wBcA9IjgXmN8LzsIrCcEXcuM-DCC2JiZRSa2ng/did.json, violations=
[])
    documento servido = construido      : true
```

El DID se resuelve con el cliente de la ERSO 007: `error=null`, y el documento servido es igual al construido en el dispositivo.

20.7 Sin registro obligatorio

La capacidad «sin depender de un registro centralizado obligatorio» se prueba con el escenario `vdr-off`: con el VDR apagado, la cartera se activa y el DID **se crea y valida localmente**; solo la publicación falla, de forma controlada, y la cartera sigue activa. Está en el recorrido de extremo a extremo, dentro del bloque de la ERSO 004 (`scripts/e2e.sh`, criterio 3).

21. Pruebas automáticas y recorrido de extremo a extremo

21.1 Pruebas

```
$ cd /home/geovani/Descargas/generic/bitacora/new_proyect
$ TEST_DB_URL=jdbc:postgresql://127.0.0.1:55432/wallet_test ./gradlew :wallet-core:test :wallet-
service:test --rerun-tasks -q 2>&1| tail -3; echo '(sin salida = todas pasaron)'
(sin salida = todas pasaron)
$ python3 - <<'EOF'
> import re, glob, html
> for pat in ['wallet-core/build/test-results/test/*WalletCoreTest*.xml', 'wallet-service/build/test-
results/test/*Erso003HolderDidTest*.xml']:
>     for f in sorted(glob.glob(pat)):
>         s = open(f, encoding='utf-8').read()
>         tot = re.search(r'name="([^\"]+)" tests="(\d+)" skipped="(\d+)" failures="(\d+)"',
s).groups()
>         print(f"{tot[0].split('.')[1]}: {tot[1]} pruebas, {tot[2]} omitidas, {tot[3]} fallos")
>         for m in re.finditer(r'<testcase name="([^\"]+)"[^>]*?(/>|>(.*)</testcase>)', s, re.S):
>             name = html.unescape(m.group(1)).removesuffix("()")
>             estado = "FALLA" if "<failure" in (m.group(3) or "") else "PASA "
>             print(f" [{estado}] {name}")
>         print()
```

```

> EOF
WalletCoreTest: 15 pruebas, 0 omitidas, 0 fallos
[PASA ] 001-C3 la politica minima permite el nivel real y lo refleja
[PASA ] 001-C2 el contrato del custodio no expone ningun metodo que devuelva material privado
[PASA ] 001-C2 la clave sirve para firmar y la firma se verifica con la publica, sin salir del
custodio
[PASA ] 003-C2 el DID Document es conforme y produce un informe de conformidad
[PASA ] 001-C2 la clave privada real no aparece en ninguna salida del custodio, ni en descriptores,
ni en firmas
[PASA ] 003 la validacion es un requisito previo - un documento no conforme no se entrega
[PASA ] 003 el SDK firma con la clave del DID usando el custodio
[PASA ] 003-C3 authentication y assertionMethod apuntan a la clave Multikey del titular
[PASA ] guarda - todo metodo de prueba devuelve void para que JUnit lo ejecute
[PASA ] 001-C3 un custodio de software declara SOFTWARE y no puede pasar por hardware
[PASA ] 001-C2 no se puede sobrescribir una clave existente ni obtener una inexistente
[PASA ] 003-C4 el documento se almacena sellado y asociado a la instancia de cartera
[PASA ] 003-C1 el DID se genera en el dispositivo sin exponer la clave privada (registro de
generacion)
[PASA ] 003-C2 el informe detecta documentos no conformes
[PASA ] 003 el identificador se deriva de la clave publica y es determinista

Erso003HolderDidTest: 10 pruebas, 0 omitidas, 0 fallos
[PASA ] flujo completo - el DID nace en el dispositivo, el backend lo publica en el VDR y queda
resoluble
[PASA ] publicar dos veces el mismo DID se rechaza y repetir la prueba es idempotente
[PASA ] el backend rechaza DID fuera del namespace de titulares, no derivados de la clave y no
conformes
[PASA ] una cartera SOFTWARE tambien publica su DID (la clave declara SOFTWARE, sin fingir
hardware)
[PASA ] guarda - todo metodo de prueba devuelve void para que JUnit lo ejecute
[PASA ] una cartera de hardware exige que la clave del DID demuestre el mismo nivel
[PASA ] el DID se deriva de la clave - mismo formato que el documento y sin datos civiles
[PASA ] una instancia no puede completar la publicacion de otra ni usar un token revocado
[PASA ] firmar el desafio con otra clave hace fallar la publicacion y no deja rastro publico
[PASA ] el respaldo cifrado tiene limites y solo lo lee su dueño

```

- **Qué hace.** Ejecuta las pruebas de wallet-core y wallet-service.
- **Qué significa.** WalletCoreTest (15; las 003-... son de esta ERSO) y Erso003HolderDidTest (10), sin fallos.

Prueba	Criterio
003-C1 el DID se genera en el dispositivo sin exponer la clave privada	1
003-C2 el DID Document es conforme..., 003-C2 el informe detecta documentos no conformes, 003 la validacion es un requisito previo...	2
003-C3 authentication y assertionMethod apuntan...	3
003-C4 el documento se almacena sellado y asociado a la instancia	4
003 el identificador se deriva de la clave publica y es determinista	1
Erso003HolderDidTest > flujo completo..., ...rechaza DID fuera del namespace...	publicación

21.2 Extremo a extremo (extracto del registro)

ERSO 2026-003 · Creación del DID y DID Document del titular (dispositivo → Wallet Backend → VDR → consumidor conforme)

· DID del titular: did:web:civica-desarrollo.avance.org.co:titulares:WI-RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmDHw6w

- ✓ PASS C1 el DID y su DID Document se generan en el dispositivo (registro de generación sin

```

material privado)
✓ PASS C2 informe de conformidad del DID Document: 10 comprobaciones, todas conformes
✓ PASS C3 authentication y assertionMethod apuntan a la clave Multikey del titular
✓ PASS publicación: el backend la entrega al VDR y la confirma leyendo la URL pública (200,
PUBLISHED)
✓ PASS C4 el documento queda sellado en el dispositivo y asociado a la instancia
✓ PASS paso 6 del diagrama: el DID es resoluble públicamente por HTTPS y sirve exactamente lo
construido en el dispositivo
✓ PASS el consumidor conforme verifica una firma del titular con la clave resuelta (ERSo 007)
✓ PASS respaldo cifrado en el backend: el backend no puede leerlo
✓ PASS un titular no puede publicar bajo el namespace de una entidad (DID_OUT_OF_NAMESPACE)
✓ PASS la validación es requisito previo: un documento con datos civiles no llega al VDR
(DID_NOT_CONFORMANT)
✓ PASS un DID ya publicado no se publica dos veces
  · 3 claves privadas de prueba registradas en secrets-did.txt (solo laboratorio) para buscarlas en
la base de datos
DID=did:web:civica-desarrollo.avance.org.co:titulares:WI-RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmdHw6w
RESULTADO did: 11 PASS · 0 FAIL
DID del titular: did:web:civica-desarrollo.avance.org.co:titulares:WI-
RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmdHw6w
didDocument: {
  "@context": [
    "https://www.w3.org/ns/did/v1",
    "https://w3id.org/security/multikey/v1"
  ],
  "assertionMethod": [
    "did:web:civica-desarrollo.avance.org.co:titulares:WI-RWVC8mA75544XCtyKnInxiAFrvKaR-
r6WjmdHw6w#key-1"
  ],
  "authentication": [
    "did:web:civica-desarrollo.avance.org.co:titulares:WI-RWVC8mA75544XCtyKnInxiAFrvKaR-
r6WjmdHw6w#key-1"
  ],
  "id": "did:web:civica-desarrollo.avance.org.co:titulares:WI-RWVC8mA75544XCtyKnInxiAFrvKaR-
r6WjmdHw6w",
  "verificationMethod": [
    {
      "controller": "did:web:civica-desarrollo.avance.org.co:titulares:WI-
RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmdHw6w",
      "id": "did:web:civica-desarrollo.avance.org.co:titulares:WI-
RWVC8mA75544XCtyKnInxiAFrvKaR-r6WjmdHw6w#key-1",
      "publicKeyMultibase": "zDnaeuU64KiK8ytgVhsWipnLdEA1ViFzVHdQygpqEQ1hXZVvk2",
      "type": "Multikey"
    }
  ]
}
resolutionMetadata: ResolutionMetadata(error=null, message=null,
contentType=application/did+json, url=https://civica-desarrollo.avance.org.co/titulares/WI-RWVC8mA...
documentMetadata: DocumentMetadata(deactivated=false, versionId=1,
contentHash=sha256:129f9d5b794d911ea2b32e0bf322360f56327acf5c94b38bcd5e8c16ebb7b166)
✓ PASS el cliente de línea de comandos (ERSo 007) también resuelve el DID del titular
✓ PASS el DID Document del titular se sirve por HTTPS en la URL calculada (200
application/did+json)
✓ PASS el documento publicado no contiene claves privadas ni datos civiles
✓ PASS el VDR registró la escritura a nombre del Wallet Backend, no del titular
✓ PASS el namespace del titular se materializó bajo el comodín titulares/* del Wallet Backend
✓ PASS C1 ninguna clave privada del titular está en la base de datos (backend + VDR)

```

PARTE V — PREGUNTAS Y RESPUESTAS

22. Preguntas sobre los conceptos

- 1. ¿Qué es un DID y en qué se diferencia de un correo o un número de documento?** Es un identificador que la persona **controla con una clave**, sin que un registro central se lo conceda ni lo pueda retirar. Un número de documento lo asigna una autoridad; un DID se deriva de una clave.
- 2. ¿Por qué `did:web` se deriva de la huella de la clave?** Es determinista (misma clave → mismo DID), no lleva datos civiles y nadie puede reclamarlo sin la clave. `did:web` no define derivación; es la regla del proyecto.
- 3. ¿Qué contiene un DID Document?** Su `id`, sus claves públicas (`verificationMethod`) y para qué sirve cada una (`authentication`, `assertionMethod`). Nunca claves privadas ni datos civiles.
- 4. ¿Qué diferencia hay entre `authentication` y `assertionMethod`?** Autenticar: demostrar quién eres (responder desafíos). Asertar: afirmar cosas (firmar). Aquí ambas apuntan a la misma clave.
- 5. ¿Qué significa «conforme» y qué no?** Que el documento cumple las **reglas estructurales** del modelo de datos (y las condiciones de la ERSO). **No** significa que pasó la suite oficial de pruebas de W3C.
- 6. ¿Por qué se valida antes de entregar el DID?** Porque un documento defectuoso, una vez publicado, es difícil de corregir y puede exponer datos. Si falla, la clave se borra y el DID no sale del dispositivo.
- 7. ¿Por qué el almacén cifra con una clave que no sale del custodio?** Para que el archivo sea inútil fuera del dispositivo: aunque lo copien, no tienen la clave de descifrado.
- 8. ¿Qué es el AAD y qué logra?** Datos que se atan al cifrado sin cifrarse (aquí instancia y DID). Si el archivo se mueve a otra instancia, el AAD cambia y no se abre.
- 9. ¿Por qué el backend no puede publicar por su cuenta?** El registro exige una prueba de posesión: firma del desafío del VDR con la clave **del DID**. El backend no tiene esa clave; solo reenvía la firma que produce el dispositivo.
- 10. ¿Qué riesgo de privacidad tiene publicar el DID de un ciudadano? Correlación:** un identificador público y persistente permite reconocer a la misma persona en contextos distintos. Por eso la publicación es **opcional** y el DID no contiene datos civiles (§26).
- 11. ¿Qué acredita el DID del titular?** Solo que quien lo presenta puede usar esa clave. **No** acredita nombre, nacionalidad ni edad, ni que el dispositivo pertenezca a una persona concreta. Eso lo aportan las credenciales (ERSO 002).
- 12. ¿Se puede cambiar la clave del DID del titular?** En el registro sí (rotación, ERSO 008), pero el Wallet Backend **no expone** ese camino: solo se implementó la creación.

13. ¿Qué pasa si se pierde la clave del DID publicado? El DID queda **huérfano**: para desactivarlo hace falta firmar con esa clave (§26).

23. Preguntas por laboratorio y por criterio

Criterio 1 (laboratorio A)

P1. *¿De dónde sale el identificador?* → De la huella RFC 7638 de la clave pública: `did:web:<dominio>:titulares:<huella>`. **P2.** *¿Qué campos del registro de generación prueban que la clave no sale?* → `keyOrigin: GENERATED`, `exportable: false`, `custodian`, `protectionLevel`. **P3.** *Búsqueda de claves privadas en la base completa:* → 18 formas buscadas, 0 coincidencias (control > 0). **P4.** *¿Por qué es significativo incluir el registro (VDR) en la búsqueda?* → Porque el backend de la cartera y el registro son los dos sitios donde, en caso de error, podría haber quedado material privado.

Criterio 2 (laboratorio A)

P5. *¿Cuántas comprobaciones tiene el informe y qué contiene cada una?* → 10 (C01-C10): id, contexto, métodos, claves Multikey, controladores, relaciones, vínculo con la clave del titular, sin clave privada, sin datos civiles, sin extensiones. **P6.** *¿Un documento con `privateKeyMultibase` qué comprobaciones activa?* → C08 y C10. **P7.** *¿Y con un `id` ajeno?* → C01, C03 y C05. **P8.** *¿Y con `assertionMethod` vacío?* → C07. **P9.** *¿Qué no es el informe?* → La suite oficial de W3C.

Criterio 3 (laboratorio A)

P10. *¿Qué valen `authentication` y `assertionMethod`?* → `["<DID>#key-1"]`, el `id` del único método de verificación, cuya clave es la Multikey del titular. **P11.** *¿Qué comprobación lo verifica?* → C07, contra la clave pública entregada por el custodio.

Criterio 4 (laboratorio A)

P12. *¿Se puede leer el DID en el archivo guardado?* → No; ni el DID ni `verificationMethod` aparecen en claro. **P13.** *Abrir con otro dispositivo / otra instancia / un byte alterado:* → los tres dan `StoreAccessException`. **P14.** *¿Qué significa «no exportable» para un documento público?* → Que el archivo es inútil fuera de su dispositivo e instancia. El documento en sí es público (se puede publicar); lo que se protege es su **almacén local** y su asociación.

Publicación (laboratorio B-D)

P15. *¿Quién firmó la prueba de posesión de la publicación?* → El dispositivo, con la clave del DID. El backend la reenvió. **P16.** *¿Quién figura como actor en el registro?* → `wallet-backend`. **P17.** *¿Publicar bajo el espacio de una entidad?* → `422 DID_OUT_OF_NAMESPACE`. **P18.** *¿Publicar un documento con datos civiles?* → `422 DID_NOT_CONFORMANT`; no llega al VDR. **P19.** *¿Qué se guarda en el backend como respaldo?* → Bytes cifrados que solo el custodio abre.

Pruebas automáticas

P20. *¿Cuántas?* → 15 (`WalletCoreTest`, compartidas con la 001) + 10 (`Erso003HolderDidTest`).

PARTE VI — CÓMO RESPONDER A CADA CRITERIO

24. Redacción modelo de las cuatro respuestas

Criterio 1 — DID y documento generados en el dispositivo sin exponer la clave privada

HolderDidService pide al custodio una clave nueva (origin = GENERATED, exportable = false), deriva el DID de la huella RFC 7638 de la clave pública (did:web:<dominio>:titulares:<huella>), construye el documento y deja un registro de generación sin ningún material privado. Una búsqueda de 18 formas textuales de las claves privadas reales en el volcado completo de la base (cartera y registro) dio 0 coincidencias. **Límite:** el custodio es simulado. **Evidencia:** §16; pruebas 003-C1.

Criterio 2 — Conforme al modelo de datos de W3C DIDs v1.1

DidConformance produce un informe de 10 comprobaciones (C01-C10) con su requisito y su referencia a la norma; el documento generado cumple las 10. El informe detecta siete tipos de documentos defectuosos, y la validación es requisito previo: si falla, la clave se borra y el DID no se entrega; el backend la repite antes de tocar el registro. **Límite:** conformidad estructural, no la suite oficial de W3C. **Evidencia:** §17; pruebas 003-C2.

Criterio 3 — Relaciones apuntan a la Multikey del titular

authentication y assertionMethod valen ["<DID>#key-1"], el id del único método de verificación, de tipo Multikey, controlado por el propio DID, con publicKeyMultibase igual a la clave pública del registro de generación. La comprobación C07 lo verifica contra la clave entregada por el custodio. **Evidencia:** §18; prueba 003-C3.

Criterio 4 — Almacenado de forma no exportable y asociado a la instancia

El documento se guarda en un archivo cifrado con AES-GCM, con una clave interna del custodio y la instancia y el DID como datos autenticados. En disco no hay texto en claro; el archivo no se abre con otro dispositivo, con otra instancia ni con un byte alterado. **Límite:** almacén simulado; la prueba en Android real (EncryptedFile/Keystore) queda pendiente. **Evidencia:** §19; prueba 003-C4.

25. Lista de comprobación para quien acepta

☐ Qué comprobar	Cómo	Resultado esperado
☐ Registro de generación	recorrido §1	<code>GENERATED</code> , <code>exportable:false</code> , <code>conformant:true</code>
☐ DID derivado de la huella	recorrido §2	<code>...:titulares:<huella></code>
☐ Sin claves privadas en la base	<code>pg_dump</code> + <code>grep -F -f</code>	0 coincidencias (control > 0)
☐ Informe de conformidad	recorrido §4	10/10, con referencias
☐ Detección de defectos	recorrido §7	cada defecto activa sus comprobaciones
☐ Documento generado	recorrido §3	<code>authentication/assertionMethod</code> → <code>#key-1; Multikey</code>
☐ Archivo sellado	recorrido §6	sin DID en claro
☐ Apertura indebida	recorrido §6	3 rechazos
☐ Publicación	recorrido §5	<code>PUBLISHED</code> , <code>CONFIRMED</code>
☐ Documento público = construido	<code>curl</code> + recorrido §8	igual
☐ Fuera del espacio	recorrido §9a	<code>DID_OUT_OF_NAMESPACE</code>
☐ Con datos civiles	recorrido §9b	<code>DID_NOT_CONFORMANT</code>
☐ Actor en el registro	auditoría del VDR	<code>wallet-backend</code> (firma del dispositivo)
☐ Respaldo ilegible	<code>wallet_did_backups</code>	bytes cifrados
☐ Pruebas automáticas	<code>./gradlew :wallet-core:test</code> <code>:wallet-service:test</code>	25/25 de la ERSO
☐ Decisión de privacidad entendida	§26	Publicación opcional y riesgo de correlación

PARTE VII — LÍMITES, HALLAZGOS Y OPERACIÓN

26. Lo que este informe NO demuestra, y lo que se encontró

26.1 ⚠ Decisión con consecuencias de privacidad: se publican DID de ciudadanos

El diagrama de arquitectura del equipo y el documento de requerimientos indican que el **Wallet Backend publica el DID Document del titular** en el VDR (`did:web`). Eso **contradice** lo que se explicó en la guía de las ERSo 004-008 («no se publica un DID por ciudadano») y hace que las ERSo 005 y 006 sigan bloqueando a las **entidades** para crear DID de ciudadanos, pero **no** al Wallet Backend.

Un DID público y persistente por titular **permite correlacionarlo** entre verificadores.
Mitigaciones adoptadas:

Mitigación	Estado
La publicación es opcional ; la creación local no la requiere	✓
El DID no contiene datos civiles (es la huella de la clave)	✓
El documento no incluye nada más que la clave y sus relaciones	✓
El Wallet Backend solo publica bajo <code>titulares/<huella></code>	✓
Rotación del identificador por contexto (un DID distinto por verificador)	✗ no implementada

Esta es una decisión de producto que debe tomarse con conocimiento.

26.2 Otros límites

Límite	Detalle
did:web para el titular	Es la lectura del diagrama («ej. <code>did:web</code> »). La ERSo admite « <code>did:web</code> u otro admitido». <code>did:key</code> habría evitado el registro por completo, pero no está en el diagrama; el adaptador <code>DidMethodAdapter</code> deja abierta la puerta.
Conformidad = estructural	Las 10 comprobaciones cubren lo que lista la ERSo y el perfil del proyecto; no ejecutan las pruebas de conformidad de W3C. El contexto usado es <code>https://www.w3.org/ns/did/v1</code> (el validador acepta también <code>.../v1.1</code>); confirmar cuál corresponde (<code>docs/VERSIONES-NORMATIVAS.md</code>).
No hay hardware seguro real	La clave «nace en el custodio» simulado y el almacén usa una clave interna del simulador. La prueba de almacenamiento no exportable sobre Android queda pendiente.
Solo CREATE	Actualizar (rotar) o desactivar el DID del titular a través del Wallet Backend no se implementó; el VDR sí lo soporta (ERSo 008). Si se pierde la clave, el DID publicado queda huérfano (ERSo 001, recuperación).

Límite	Detalle
Dos claves por dispositivo, dos roles	La de la instancia (identifica la cartera) y la del DID (identidad del titular). Se exige que la del DID demuestre al menos el mismo nivel que la cartera.
Respaldo cifrado	El backend guarda bytes opacos que solo el custodio abre. Restaurar un respaldo en un dispositivo nuevo no está implementado (la clave privada no viaja; sería un DID nuevo).
Criterio 1 repetido en el PDF	El PDF lista el criterio 1 dos veces (primera y última fila); se trató como uno. Confirmar con quien redactó la ERSO.
Fechas	La prueba (30-sep) es posterior a esta implementación.

26.3 Hallazgo heredado: HEAD responde 404 en el registro

Descubierto en la ERSO 005. Afecta al DID publicado del titular igual que a cualquiera; no altera los criterios.

27. Si algo no sale como en el informe

Síntoma	Causa probable	Qué hacer
El simulador imprime el uso	Imagen <code>holder-sim</code> anterior	<code>./gradlew :wallet-sim:installDist</code> y <code>docker compose --profile tools build holder</code>
DIDT o TH vacíos	El recorrido no llegó a imprimir DID=	Repetir el paso A y revisar errores
502 / 422 al publicar	El VDR está apagado o <code>wallet-backend</code> sin credenciales	Revisar <code>CLIENT_SECRET_WALLET</code> y el estado de <code>vdr</code>
DID_OUT_OF_NAMESPACE inesperado	El DID no se derivó de la clave	Usar el flujo del recorrido
NAMESPACE_NOT_OWNED al publicar	Falta el comodín <code>titulares/*</code>	Ver ERSO 004 (reservar <code>titulares/*</code> a <code>wallet-backend</code>)
404 en la URL pública	El DID no se publicó	Revisar <code>wallet_did_publications.status</code>
Pruebas no conectan	Falta <code>vdr-test-pg</code>	Levantarla (puerto 55432)

28. Operación diaria

```
cd deploy
docker compose up -d           # levantar
docker compose --profile tools down # bajar (NUNCA con -v)
bash scripts/lab-003-completo.sh # repetir todos los laboratorios
```

- **Ver los DID publicados por titulares:** `select did, status from wallet_did_publications.`
- **Ver el historial de uno:** `GET /admin/v1/documents/{did}/versions` (administración; ERSO 008).

ANEXOS

Anexo A — Los scripts

Script	Para qué sirve
scripts/lab-003-completo.sh	Ejecuta los laboratorios en una sola sesión
scripts/e2e.sh	Recorrido de extremo a extremo (121 comprobaciones)
scripts/generar-pdf.sh	Convierte un informe a PDF

Anexo B — Autocomprobación (con respuestas)

1. ¿De dónde sale el identificador? → De la huella de la clave pública.
2. ¿Cuántas comprobaciones de conformidad hay? → 10.
3. ¿Qué comprobación vincula las relaciones con la clave del titular? → C07.
4. ¿Qué algoritmo cifra el archivo sellado? → AES-GCM con clave interna del custodio.
5. ¿Qué se ata como AAD? → La instancia y el DID.
6. ¿Quién firma la prueba de posesión de la publicación? → El dispositivo.
7. ¿Qué actor figura en el registro? → `wallet-backend`.
8. ¿Qué riesgo de privacidad tiene publicar el DID? → Correlación.
9. ¿Se puede rotar el DID del titular desde el backend? → No; solo creación.
10. ¿Qué NO acredita el DID? → Nombre, nacionalidad, edad ni la persona civil.

Anexo C — Ejercicios del método (con respuesta modelo)

Ejercicio 1. Descompón el criterio 4. → Verbos: *almacenado, no exportable, asociado a la instancia*. Evidencia: prueba de almacenamiento. Casos negativos: otro dispositivo, otra instancia, byte alterado. Mecanismo: AES-GCM + AAD + clave interna.

Ejercicio 2. Diseña una prueba para «el informe de conformidad no es decorativo». → Tomar un documento correcto, aplicar defectos conocidos y comprobar que fallan precisamente las comprobaciones esperadas (§17.2).

Ejercicio 3. Evalúa la decisión de publicar DID de ciudadanos. → Beneficio: resolución pública y verificación sin canal privado. Riesgo: correlación por identificador persistente. Alternativas: no publicar; `did:key`; un DID por contexto; publicar solo bajo petición. Decisión de producto (§26.1).

Anexo D — Referencias

- W3C — Decentralized Identifiers (DIDs) v1.1.
- Método `did:web`; Multikey y multibase.
- RFC 7638 (huella de clave JWK).
- NIST SP 800-38D (AES-GCM).

- docs/VERSIONES-NORMATIVAS.md , docs/MARCO-CONCEPTUAL.md , docs/COMO-SE-RESOLVIO-CADA-CRITERIO.md .